

정적분석 결과 보고서

AI 역량테스트 플랫폼 · 증적관리 05_시큐어코딩

최초 점검일: 2026-08-06 조치 및 재검증일: 2026-08-06 대상: backend/, frontend/ (실제 저장소 코드/의존성)

1. 점검 개요

항목	내용
점검 대상	backend (Node.js/Express), frontend (React/Vite)
사용 도구	npm audit (의존성 취약점), oxlint (정적 코드 분석), 수동 코드 검토
점검 범위	전체 프로덕션/개발 의존성, frontend/src 전체 소스
최초 결과	High 1건(2 패키지), Moderate 1건, Low 3건(총 7개 위치)
조치 후 결과	oxlint 7건 전부 수정 완료(0건 잔존), postcss 패치 완료, 로컬 빌드 검증 통과. react-router-dom은 위험 낮음으로 조치 보류

2. npm audit — 의존성 취약점

backend

```
$ npm audit
found 0 vulnerabilities (81 dependencies scanned)
```

frontend — 조치 전

```
$ npm audit
3 vulnerabilities (1 moderate, 2 high)

High   react-router / react-router-dom (7.12.0 - 8.2.0)
       RSC Mode CSRF Bypass Allows Action Execution Before 400 Response

Moderate postcss (<=8.5.22)
        Incomplete fix of GHSA-6g55-p6wh-862q — sourceMappingURL arbitrary .map read
```

frontend — 조치 후

```
postcss: 8.5.20 → 8.5.25 (package.json ^8.5.23으로 상향, node_modules 갱신 완료)
→ Moderate 취약점 해소

react-router-dom: 조치 보류
→ 취약 범위 7.12.0~8.2.999 전체이며 현재 패치 버전 없음
```

→ 코드 검토 결과 BrowserRouter 기반 순수 클라이언트 SPA로 RSC 모드 미사용
 → 실제 공격 경로 없음으로 판단, 다운그레이드에 따른 기능 손실 리스크가 더 커서 보류
 → 패치 릴리스(>=8.3.0 또는 7.x 후속 패치) 공개 시 재평가 예정

3. oxlint — 정적 코드 분석 (frontend/src)

조치 전: 7건 warning 탐지 (error 0건)

규칙	파일	조치 내용
react-hooks/exhaustive-deps	CommunityTab.jsx	load를 useCallback으로 고정, 의존성 배열에 추가
react-hooks/exhaustive-deps	NoticeManagementTab.jsx	load를 useCallback으로 고정, 의존성 배열에 추가
react-hooks/exhaustive-deps	InvitationSettingsTab.jsx	load를 useCallback으로 고정, 의존성 배열에 추가
react-hooks/exhaustive-deps	ManagerExamDetailPage.jsx	load/headers를 useCallback·useMemo로 고정
eslint/no-unused-vars	MobileProctoringPage.jsx	catch(firstErr)에 console.warn 로깅 추가
eslint/no-unused-vars	ProblemCreationChatbot.jsx	미사용 import 2건(generateCandidates, refineCandidate) 제거

조치 후 재검증: 0건 (node_modules/.bin/oxlint --format=json src → diagnostics: [])

```
$ oxlint --format=json src
{ "diagnostics": [], "number_of_files": 58, "number_of_rules": 92 }
```

※ 참고: useEffect 의존성 배열에 함수를 단순 추가할 경우 매 렌더링마다 함수가 재생성되어 무한 재렌더링을 유발할 수 있어, 4건 모두 useCallback(및 필요한 경우 useMemo)으로 참조를 고정하는 방식으로 조치함. 이후 로컬 환경에서 npm install(package-lock.json 동기화) 및 npm run build를 실행한 결과, 1885개 모듈이 오류 없이 정상 빌드됨을 확인함(vite v8.1.4, built in 1.61s).

4. 수동 보안 코드 검토

다음 항목에 대해 backend/src, frontend/src 전체를 대상으로 패턴 검색을 수행하였다.

점검 항목	결과	비고
eval() / new Function() 사용	미발견	코드 인젝션 위험 없음

child_process.exec 등 명령 실행	미발견	OS 커맨드 인젝션 위험 없음
dangerouslySetInnerHTML 사용	미발견	저장형 XSS 위험 없음
SQL 문자열 결합 방식 쿼리	미발견	pg 쿼리는 파라미터 바인딩 사용
하드코딩된 API 키/시크릿	미발견	환경변수(process.env) 기반 사용
비밀번호 평문 저장	미발견	scrypt+salt 해싱, timingSafeEqual 비교

5. 검증 완료 / 남은 작업

- package-lock.json 동기화 완료 (로컬 npm install 실행, postcss 8.5.25 반영)
- 프로덕션 빌드 검증 완료 (로컬 npm run build, 오류 0건)
- [남은 작업] react-router-dom 패치 릴리스 모니터링 — 공개 시 업그레이드 및 회귀 테스트 진행
- 상세 조치 항목 및 상태는 취약점조치내역.xlsx 참조